

IT Security Basics

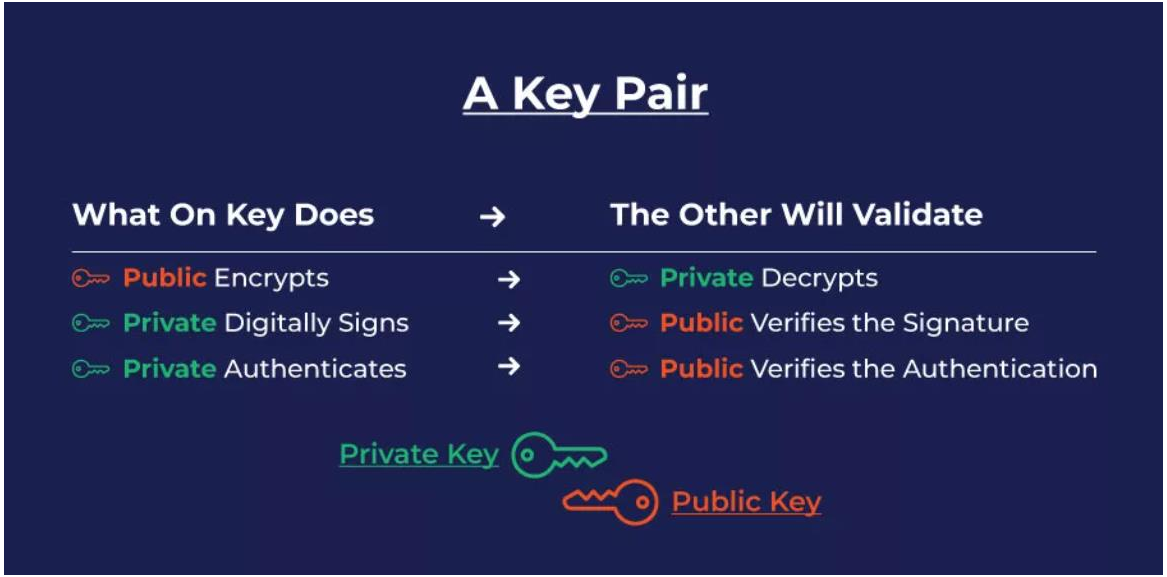
PKI, Certificates and Hash Values

Digital Certificates

FH University of Applied Sciences TECHNIKUM WIEN

What has happened so far…

- Remember:
  - We use the public key of an recipient to encrypt data for them
  - We use the public key of an sender to verify the digital signature and check the authenticity of the sender



Source: https://signmycode.com/blog/what-is-x-509-certificate-how-it-works-and-how-to-to-obtain-it

What has happened so far…

- Do you see the problem with this?

What has happened so far…

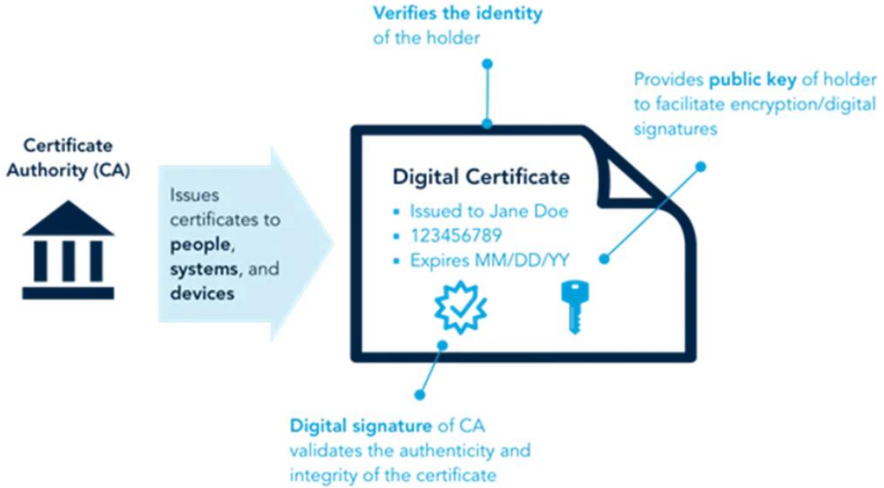
- Do you see the problem with this?

- How can I make sure that the public key I have really belongs to the sender / recipient?
  - In the end Eve (= attacker) could just tell me she is Bob (= recipient) and send me her public key in the name of Bob.

Digital Certificates

- Digital form of identification
  - Like a passport in real life
- Ensuring that a public key belongs to a person or company
- Certificates prevent us from being "foisted" with a false public key

- Only certificates guarantee messages’
  - Authenticity
  - Confidentiality
  - Integrity
  - Non-repudiation



Source: https://www.quantumbooks.com/business/it/advantages-and-disadvantages-of-digital-certificates/

Certificate authority

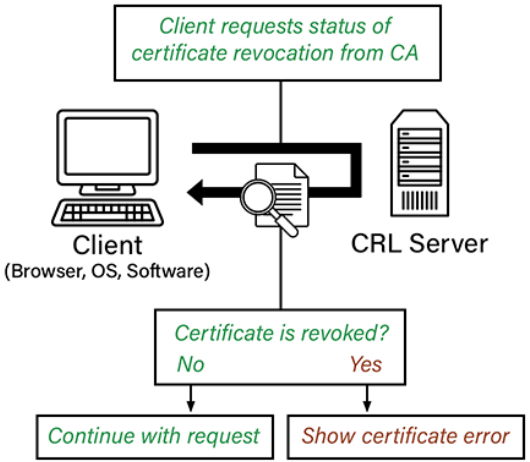
- The Certificate Authority (CA) issues certificates and guarantees that the content of the certificate is valid and was actually issued to the person or company named in the certificate

- Certificates can be issued by
  - Organizations (e.g. A-Trust, VeriSign)
  - Public institutions or government agencies (Bürgerkarte) companies

- The certificate itself is signed with the private key of the CA

Certificate revocation

- Users not only need to be able to easily check the information on a certificate, but also whether a certificate is still valid at all
- If the certificate owner e.g. "loses" the private key, the certificate must be classified as invalid
- This is done via certificate revocation lists (CRL) that are maintained by the CAs
- These lists can e.g. be loaded into applications and an attempt to use a revoked key will block the application



Source: https://www.ssltrust.com/blog/how-certificate-revocation-works

Online Certificate Status Protocol (OCSP)

- The fact that the user has to make sure that his CRL is up-to-date with the method mentioned is a disadvantage

- The Online Certificate Status Protocol (OCSP) allows a certificate check via the Internet, so no lists need to be imported

- Servers (called responders) host CRLs and respond to OSCP requests as to whether the certificate is "good", "revoked" or "unknown".

X.509 Standard

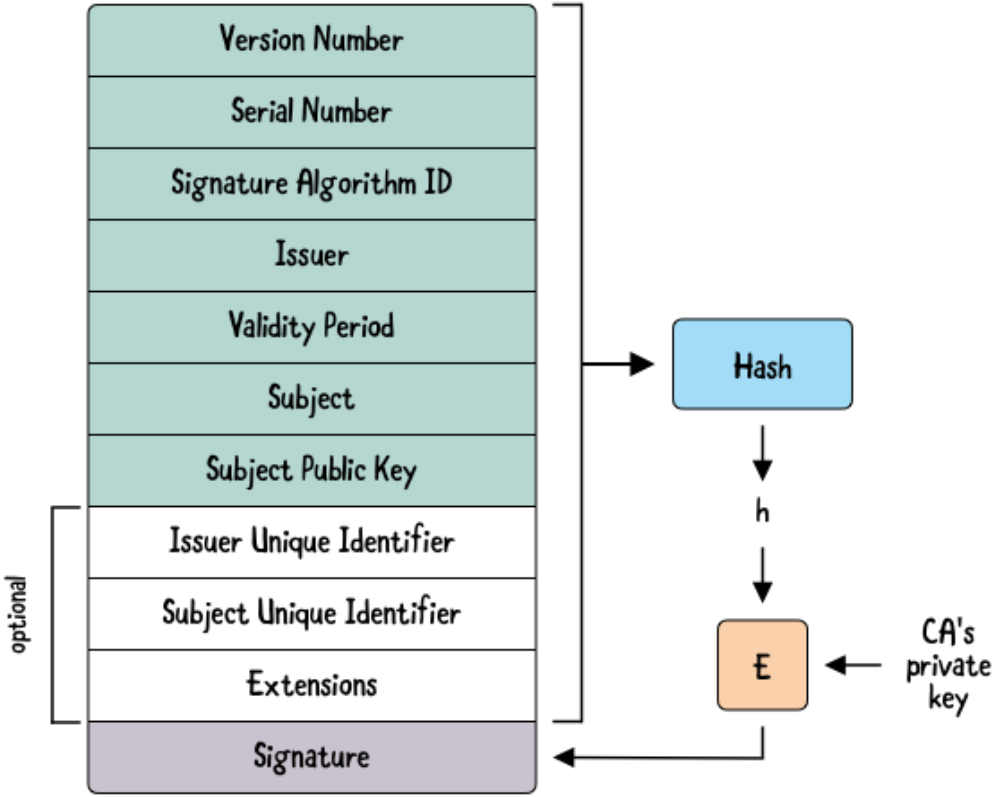
- The information that a certificate must contain is regulated in the X.509 standard (current version 3).

- tbsCertificate: Key information of the certificate:
  - version: Used to describe the format of the certificate
  - serialNumber: Unique identifier of the certificate.
  - signature: Identification of the algorithm used by the CA to sign this certificate (same as the signatureAlgorithmVersion field).
  - issuer: Name of the issuing entity.
  - validity: The period of validity of the certificate specified over a period of time.
  - subject: Unique identifier of the certificate subject (user).
  - subjectPublicKeyInfo: Key information

X.509 Standard

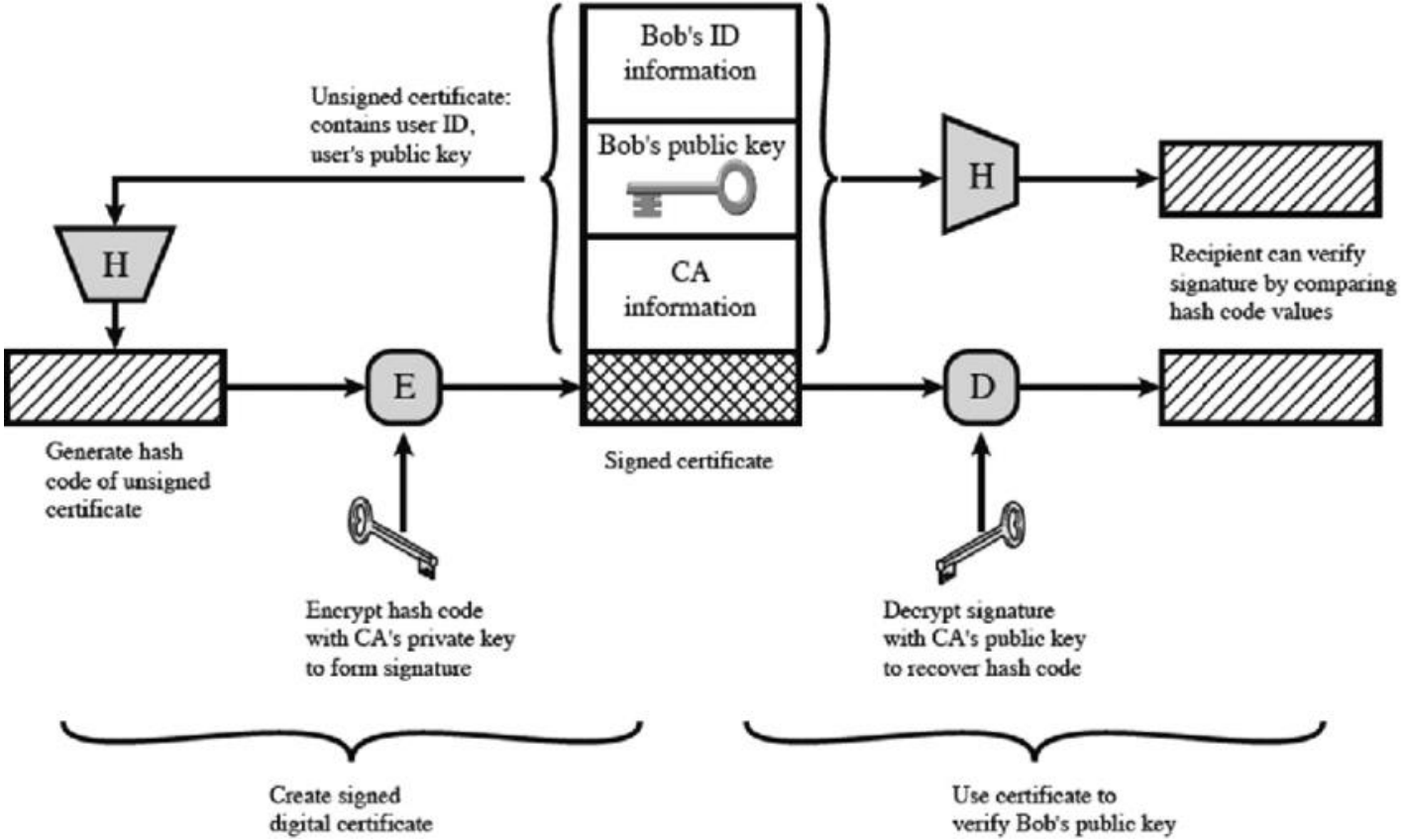
- tbsCertificate: Key information of the certificate:
  - issuerUniqueID: Unique ID of the issuer (optional).
  - subjectUniqueID: Unique ID of the subject (optional).
  - extensions: Extensions.
  - signatureAlgorithm: Applied CA algorithm
  - signatureValue: Signature of the CA

X.509 Certificate



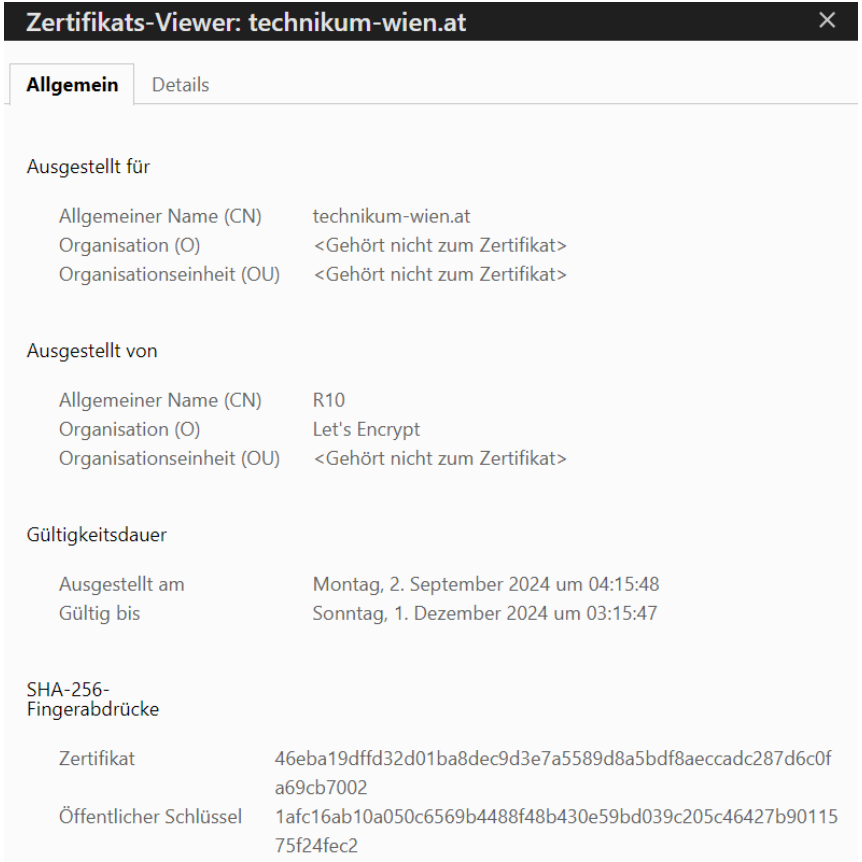
Source: https://comp38411.jtang.dev/docs/public-key-infrastructure/x509-certificates/

Use of public key in certificates



Source: https://www.researchgate.net/figure/Public-key-certificate-use-9-60_fig16_313771638

Example: Certificate of technikum-wien.at



Public Key Infrastructure

FH University of Applied Sciences TECHNIKUM WIEN

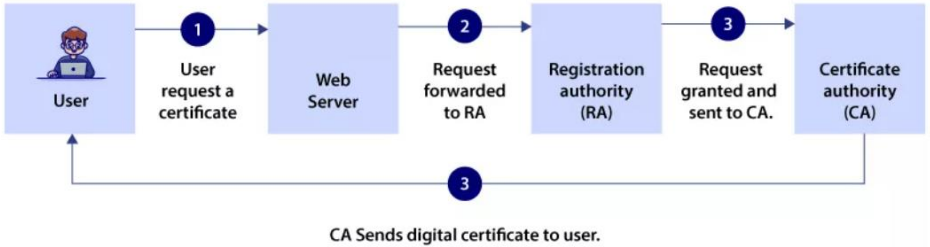
Public Key Infrastructure (PKI)

- Need to:
  - create certificates
  - administer certificates
  - distribute certificates
  - save certificates
  - withdraw certificates
- ⇒it requires a whole lot of hardware, software, people, policies, procedures, etc.

- All of this is summarized under the term Public Key Infrastructure (PKI).

Public Key Infrastructure (PKI)

- The end user generates a key pair and has the public key signed by a trust center by applying for a certificate from a Registration Authority (RA).
- RA is an executive body of a Certification Authority (CA) and controls the identity of the user (badge)
- The certificate is signed by the CA when the information is correct
- This allows other users to verify the authenticity of the certificate
- If a certificate has to be revoked before it expires (e.g. when the private key becomes known), it is placed on a revocation list (CRL).

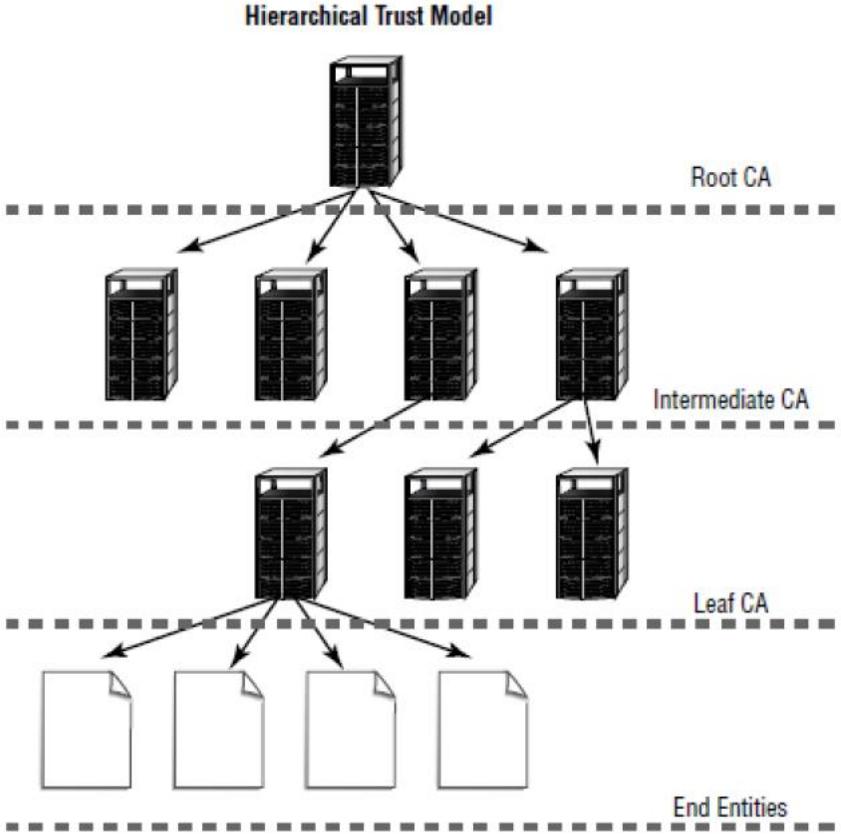


Source: https://signmycode.com/blog/what-is-x-509-certificate-how-it-works-and-how-to-to-obtain-it

Hierarchical Trust Model

- In a hierarchical trust model, the root CA at the top provides all information.

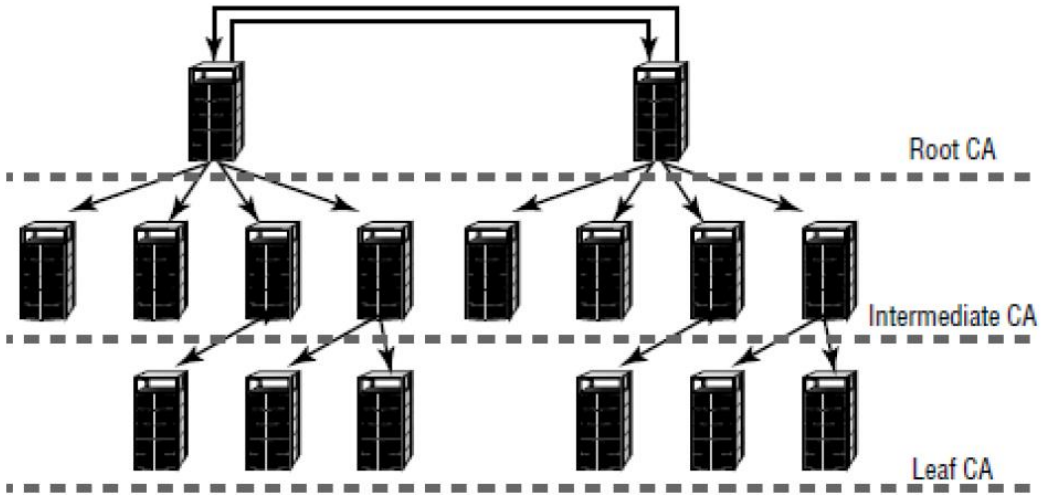
- Each CA trusts information from the same level or above



Source: https://www.slideserve.com/joy/cist-1601-information-security-fundamentals

Bridge Trust Model

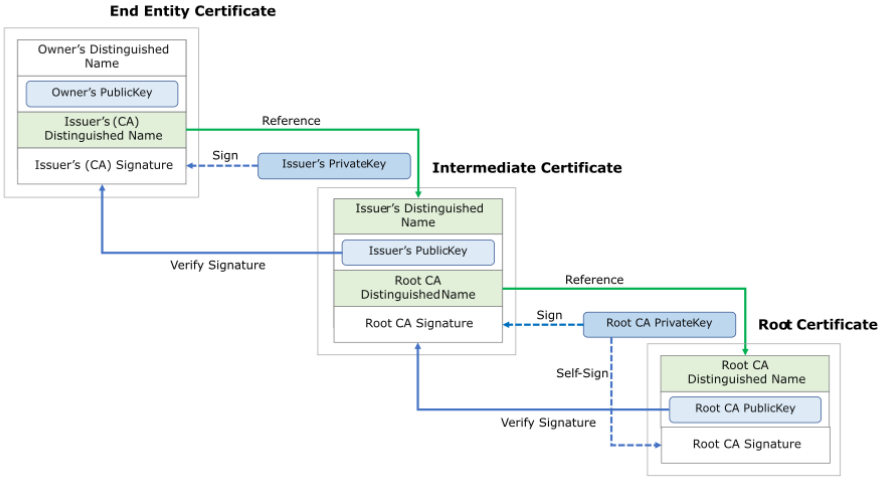
- There are several Root CAs that trust each other
- This enables cross certification of the root CAs



Source: https://www.slideserve.com/joy/cist-1601-information-security-fundamentals

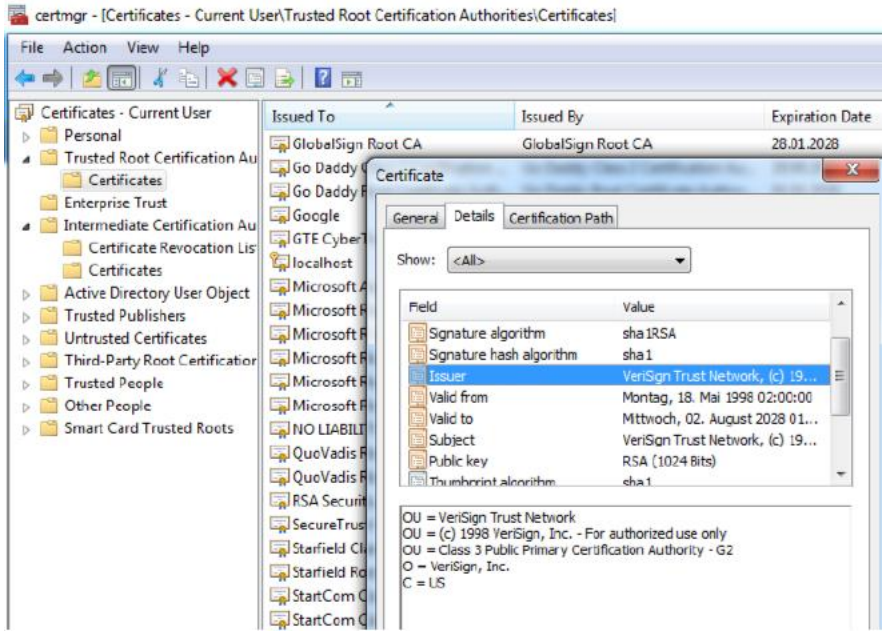
Chain of trust

- Since not all certificates can be issued by the root CA in a hierarchical PKI, intermediates are used
- This certification path is called Chain of Trust. At the top of the tree is the root certificate from the root CA. This can be recognized by the fact that the owner (subject) and signer (issuer) are identical



Source: https://cheapsslsecurity.com/blog/what-are-root-certificates-and-intermediate-certificates/

ROOT-Certs on operating systems



- Windows: *certmgr.msc*
- Linux: *ls /etc/ssl/certs/*.pem*

Hash Values

FH University of Applied Sciences TECHNIKUM WIEN

Hash-Value

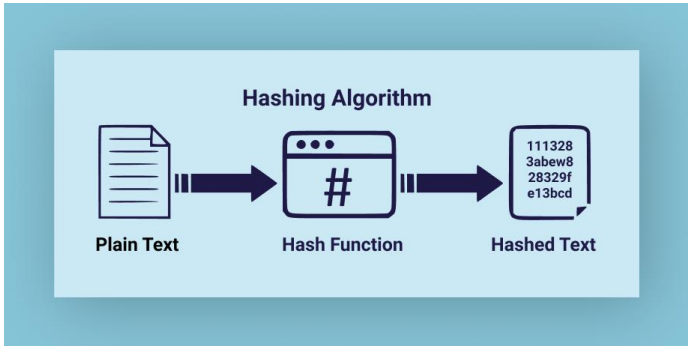
- Not directly an encryption since one-way function
- Tool used in encryption and security
  - Used to protect integrity
  - Used in digital signatures
  - Used to store passwords

- Example Algorithms:
  - SHA-256 or SHA-512

- Not secure any longer
  - MD5 or SHA-1

Hash-Value

- A hash value
  - ...is a kind of fingerprint for an input value
  - ...is a mathematical one-way function
  - ...can be calculated very quick
  - ...has a fixed length (depending on the mathematical function)
  - ...changes completely if only 1 character in the input value changes
  - …is collision resistant



Source: https://medium.com/nybles/hashing-algorithms-d10171ca2e89

Hash Algorithms

Comparison of SHA Parameters

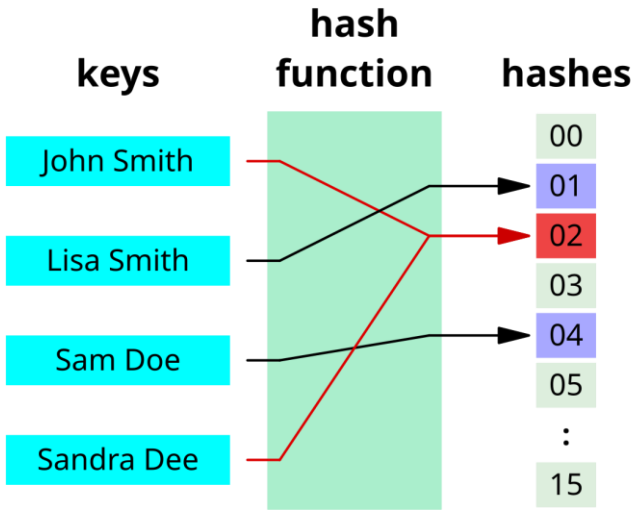
	SHA-1	SHA-256	SHA-384	SHA-512
Message digest size	160	256	384	512
Message size	$<2^{64}$	$<2^{64}$	$<2^{128}$	$<2^{128}$
Block size	512	512	1024	1024
Word size	32	32	64	64
Number of steps	80	80	80	80
Security	80	128	192	256

Notes:
1. All sizes are measured in bits.
2. Security refers to the fact that a birthday attack on a message digest of size n produces a collision with a work factor of approximately $2^{n/2}$.

Source: https://www.omscs-notes.com/information-security/hashes/

Collision resistance

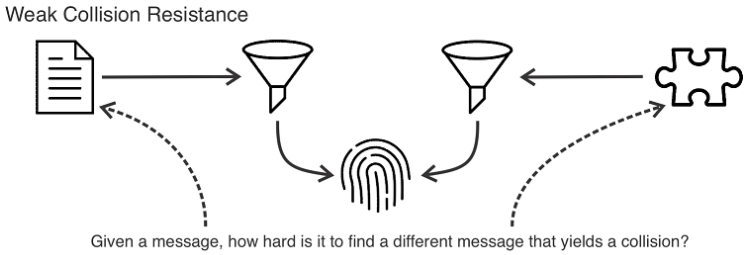
- Problem:
  - Set of possible preimages is infinite, but set of possible hash values is finite.
- It must therefore be possible to map different preimages to the same hash values (=collision).
- Figuring out collisions on purpose should be nearly impossible, though.



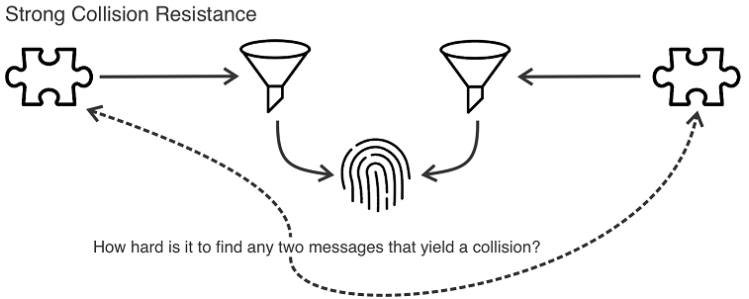
Source: https://en.wikipedia.org/wiki/Hash_collision#/media/File:Hash_table_4_1_1_0_0_1_0_LL.svg

Collision resistance

- Weak collision resistance:
  - Attacker already knows the hash value of message x and also the message
  - It is hard to find another message x’ that creates the same hash value then the given message x: H(x)=H(x’)



- Strong collision resistance:
  - No hash value or message is known by attacker
  - It is hard to find two messages x and x’ that creates the same hash value: H(x)=H(x’)



Source: https://livebook.manning.com/book/full-stack-python-security/chapter-2/v-3/42